

أهداف التعلم

- اشرح المراحل العامة للاستجابة للحوادث والغرض من كل مرحلة.
- استخدم التأثير والاحتمالية لتحديد أولويات المخاطر في النموذج المبسط للدرس.
- صمم استجابة مبررة لحادث أمني، واربط إجراءات الاستجابة بالضوابط الوقائية المناسبة.

حتى مع استخدام تقنيات الحماية والدفاع في العمق، قد يقع حادث أمني؛ لذلك ينتقل هذا الدرس من الوقاية إلى الاستجابة وإدارة المخاطر.

حتى النظام المحمي جيدًا قد يتعرض لحادث أمني، مثل تسرب بيانات أو التلاعب بالملفات أو تعطل خدمة. لذلك تستخدم المؤسسات خطة منظمة لوقف انتشار المشكلة، وإزالة التهديد، واستعادة الخدمة، ثم التعلم من الحادث وتحسين الحماية. ويعرض هذا الدرس نموذجًا تعليميًا مبسطًا من ست مراحل؛ وقد تتداخل بعض أنشطته أو تتكرر بحسب طبيعة الحادث. كما تُقيَّم المخاطر لتحديد أولويات المعالجة، لأن الفريق لا يستطيع معالجة كل المخاطر في الوقت نفسه.

؟ السؤال الرئيسي: عندما يقع حادث أمني، كيف ينبغي للمؤسسة أن تنظّم استجابتها عبر مراحلها العامة – وكيف تقرر أي المخاطر تعالجها أولًا؟

⭐ خريطة الدرس

الفكرة الأساسية:

تمثل مراحل الاستجابة الست تسلسلًا عامًا يساعد على تنظيم الاستجابة، مع إمكانية تداخل بعض الأنشطة أو العودة إلى مراحل سابقة بحسب الحادث؛ ويحدد تقييم المخاطر الأولويات بناءً على التأثير × الاحتمالية.

المفاهيم الأساسية:

- الحادث الأمني
- المراحل الست
- الاحتواء / الاستئصال
- المخاطرة = التأثير × الاحتمالية

مصطلحات أساسية

الحادث الأمني – حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية.

📌 ملحوظة مهمّة

1. ماهية الحادث الأمني

(1) **الحادث الأمني**: حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية.

(2) أمثلة نموذجية على الحوادث الأمنية

النوع	الوصف
تسرب المعلومات	تسرب المعلومات الشخصية أو السرية إلى الخارج
التلاعب بالبيانات	تعديل البيانات داخل نظام ما دون تصريح
انقطاع الخدمة	تصبح الخدمة غير متاحة بسبب هجمات على الخادم، إلخ.

2. تدفق الاستجابة للحوادث



الاحتواء: اعزل الجزء المتأثر أو قيّد أثره بالطريقة المناسبة لمنع انتشار المشكلة.

(1) يعرض هذا الدرس نموذجًا تعليميًا مبسطًا للاستجابة للحوادث من ست مراحل كما يأتي.

المرحلة	الوصف
① التحضير	إنشاء إجراءات وهياكل استجابة مسبقًا، استعدادًا للحوادث
② الاكتشاف	اكتشاف وتأكيد وقوع حادث
③ الاحتواء	تحديد نطاق التأثير بحيث لا ينتشر الضرر أكثر

المرحلة	الوصف
④ **إزالة التهديد (الاستئصال)**	إزالة التهديد ومسبباته، مثل حذف البرمجيات الخبيثة ومعالجة الثغرة المستغلة
⑤ **الاستعادة**	إعادة الأنظمة والخدمات إلى حالة تشغيل آمنة وطبيعية (قد تشمل الاستعادة من نسخة احتياطية سليمة)
⑥ **الدروس المستفادة والتحسين**	تحليل ما حدث، وتوثيق الدروس، وتحسين الضوابط لتقليل احتمال التكرار وأثره



الشكل 2.3.1 – نموذج تعليمي مبسط للاستجابة للحوادث من ست مراحل

(2) يساعد ترتيب المراحل على فهم التسلسل العام، لكن الاستجابة الفعلية قد تتضمن تداخلًا أو تكرارًا بين بعض الأنشطة. فمثلًا، قد يكشف الاسترداد عن بقايا للتهديد تستلزم العودة إلى الاحتواء أو إزالة التهديد.

3. مفهوم تقييم المخاطر



قيّم أثر كل خطر واحتمال وقوعه، ثم حدّد المخاطر الأعلى أولوية.

(1) **الخطر**: احتمال أن يقع حدث يسبب ضررًا، مع مراعاة احتمال وقوعه وحجم أثره.

(2) في هذا الدرس نستخدم طريقة مبسطة لتقدير درجة الخطر اعتمادًا على عاملين:

درجة الخطر = درجة التأثير × درجة الاحتمالية

① **التأثير**: حجم الضرر إذا وقع الحدث.

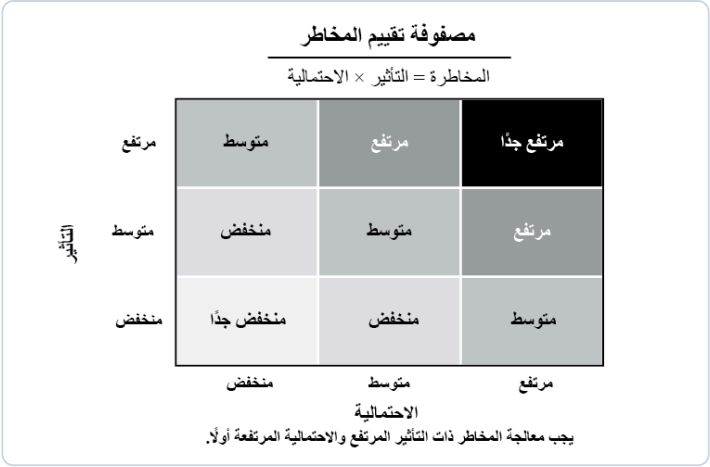
② **الاحتمالية**: مدى احتمال وقوع الحدث.



الاستعادة: إعادة الأنظمة والخدمات إلى حالة تشغيل آمنة وطبيعية؛ وقد تشمل الاستعادة من نسخة احتياطية سليمة.

💡 توقّف وفكّر

لماذا يجب أن يأتي الاحتواء قبل الاستئصال في الاستجابة ذات المراحل الست؟



الشكل 2.3.2 – مصفوفة تقييم المخاطر

(3) تُعد المخاطر ذات التأثير العالي والاحتمالية العالية من أعلى الأولويات في هذا النموذج المبسط. أما ترتيب الحالات الأخرى فيعتمد على درجات المصفوفة والسياق والضوابط المتاحة.

الفكرة الرئيسة

تعامل مع الحوادث وفق التسلسل العام – احتوِ، ثم أزل السبب، ثم استعد، ثم استخلص الدروس المستفادة وحسّن الضوابط لتقليل احتمال التكرار – وحدد أولويات المخاطر بناءً على التأثير × الاحتمالية، بحيث يظل الضرر صغيرًا ولا تتكرر المشكلات.

مصطلحات أساسية

التأثير – مقدار الضرر إذا وقعت المخاطرة.

الاحتمالية – مدى احتمالية وقوع المخاطرة.

✎ مثال محلول

(1) ضع علامة ○ أمام كل عبارة (أ - د) إذا كانت صحيحة، أو علامة × إذا كانت خاطئة.

أ الحادث الأمني حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية.

ب في الاستجابة للحوادث، من المهم أولًا منع انتشار الضرر قبل إزالة السبب.

جـ يمكن تحديد حجم المخاطرة بالتأثير وحده.

د المرحلة الأخيرة من الاستجابة للحوادث هي الدروس المستفادة والتحسين.

(2) لكل من أ - د، بيّن أي مرحلة من المراحل الست للاستجابة للحوادث (أ - د) تنتمي إليها.

أ إنشاء إجراءات استجابة مسبقًا، استعدادًا للحوادث

ب فصل حاسوب مصاب بالبرمجيات الخبيثة عن الشبكة

جـ إزالة إصابة البرمجيات الخبيثة

د تحليل السبب واتخاذ التدابير اللازمة لضمان عدم تكرار الحادث نفسه

[الخيارات] أ التحضير ب الاحتواء جـ الاستئصال د الدروس المستفادة والتحسين

✓ الحلّ

(1)

أ تعريف صحيح للحادث الأمني. لذلك، ○.

ب يُجرى الاحتواء (منع انتشار الضرر) قبل الاستئصال (إزالة السبب). لذلك، ○.

جـ يُحدَّد حجم المخاطرة بكل من التأثير والاحتمالية معًا. لذلك، ×.

د المرحلة الأخيرة من المراحل الست هي الدروس المستفادة والتحسين. لذلك، ○.

(2)

أ: التحضير المسبق هو التحضير. **أ**

ب: الفصل عن الشبكة لمنع انتشار الضرر هو الاحتواء. **ب**

ج: إزالة البرمجيات الخبيثة هي الاستئصال. **ج**

د: تحليل السبب وتحسين الضوابط هما الدروس المستفادة والتحسين. **د**

تدرّب

1 أجب عن الأسئلة التالية.

1. ما المصطلح الذي يُطلق على حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية؟
2. اذكر المراحل الست للاستجابة للحوادث حسب تسلسلها العام.
3. ما العاملان المستخدمان لتحديد حجم المخاطرة؟

2 أجب عن الأسئلة التالية.

(1) من بين الخيارات التالية (أ - د)، اختر الخيار الذي لا يمثل مثالًا مناسبًا لحادث أمني.

أ تم تشفير البيانات بسبب إصابة ببرنامج فدية.

ب تسربت معلومات العملاء إلى الخارج عبر وصول غير مصرح به.

ج تم إجراء تحديث للبرنامج لإضافة ميزات جديدة.

د أصبحت خدمة ويب غير متاحة بسبب هجوم على الخادم.

(2) من بين الخيارات التالية (أ - د)، اختر الخيار الذي يصف مفهوم تقييم المخاطر بأنسب طريقة.

أ يكفي معالجة المخاطر ذات التأثير الكبير فقط.

ب يكفي معالجة المخاطر ذات الاحتمالية العالية فقط.

ج ينبغي معالجة المخاطر ذات التأثير العالي والاحتمالية العالية أولًا.

د يجب معالجة جميع المخاطر في آن واحد.

⚙️ فكّر كمهندس: ابحث ثم قرر

تعرّض نظام سجلات الطلاب في إحدى المدارس لهجوم ببرمجية فدية: شُفّرت الملفات، ولم يعد الموظفون قادرين على تسجيل الدخول. أنت تقود الاستجابة.

1 · استجب من هنا. تم للتو اكتشاف هذا الحادث – الملفات مشفرة والموظفون محظورون من الدخول. بدءًا من الموقف الذي تمر به المدرسة الآن، اذكر المراحل التي لا يزال يتعين تنفيذها، وبيّن ماذا تعني كل منها بالنسبة لهذا الحادث تحديدًا.

2 · قيّم المخاطر. بالنسبة لمخاطرتين تواجههما المدرسة – (i) هجوم آخر ببرنامج فدية، (ii) انقطاع كهرباء قصير – قدّر التأثير والاحتمالية، وبيّن أيهما ينبغي معالجته أولًا.

3 · قرّر. أوصِ بأول ثلاثة إجراءات ينبغي أن تتخذها المدرسة، وقدّم سببًا واحدًا لأهمية الترتيب. **في أزواج،** قارنا ترتيبيكما واتفقا معًا على الخطوة الأولى الأهم.

☐ **الاستعادة من النسخة الاحتياطية فورًا**

☐ **اتباع الاستجابة ذات المراحل الست بالترتيب**

قدّم دليلًا على إجابتك.

هل تواجه صعوبة؟ إذا بدأت الاستعادة قبل إزالة التهديد، فقد تبقى البرمجية الخبيثة أو الثغرة المستغلة، وقد يلزم الرجوع إلى الاحتواء وإزالة التهديد.

📝 سؤال على نمط الامتحان

اشرح أهمية التسلسل العام لمراحل الاستجابة للحوادث، مستخدمًا الاحتواء والاستئصال والاستعادة كمثال، ووضّح لماذا قد تحتاج الاستجابة الفعلية إلى العودة إلى مرحلة سابقة. **[6 درجات]**

استعن بـ: ما يحدث إذا بدأت الاستعادة قبل إزالة السبب.

🌍 طبّق ما تعلمته

اكتشف متجر إلكتروني للتو أن بيانات العملاء قد **تسرّبت**. باستخدام مراحل الاستجابة الست وتقييم المخاطر، حدد المرحلتين التاليتين اللتين يجب على المتجر تنفيذهما وسبب ذلك، وحدد خطرًا واحدًا ينبغي إعطاؤه الأولوية بعد ذلك.

❓ إجابة السؤال الرئيسي

طرح الدرس سؤالًا حول كيفية الاستجابة لحادث أمني وتحديد أولويات المخاطر. الحادث الأمني حدث يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، أو يخالف سياسة أمنية. ويعرض الدرس نموذجًا مبسطًا من ست مراحل: التحضير، والاكتشاف، والاحتواء، وإزالة التهديد (الاستئصال)، والاستعادة، ثم الدروس المستفادة والتحسين. يساعد هذا التسلسل على الفهم، لكن بعض الأنشطة قد تتداخل أو تتكرر. ولتحديد الأولويات، نقدّر درجة الخطر في هذا الدرس من درجتي التأثير والاحتمالية، ثم نبدأ بالمخاطر الأعلى أولوية بهدف تقليل الضرر واحتمال تكرار المشكلة.

تمارين

1 اختبر فهمك: أجب عن الأسئلة الآتية دون الرجوع إلى قسم «ملحوظة مهمة»، ثم راجع إجاباتك.

2 اقرأ الفقرة التالية وأجب عن كل سؤال.

يُسمى الحدث الذي يؤثر في سرية المعلومات أو سلامتها أو توافرها، أو يهددها بجدية، (أ). وفي نموذج الدرس، يُستخدم (ب) للحد من انتشار الضرر، ثم تُنفذ (ج) لإزالة التهديد ومسبباته، وتليها (د) لإعادة الأنظمة والخدمات، ثم تأتي (هـ) لتحليل ما حدث وتحسين الحماية.

1. املأ الفراغات (أ)-(هـ).

3 أجب عن الأسئلة التالية.

(1) استخدم مصفوفة الدرس والقيم المعطاة لتحديد أولوية المخاطر (أ - د). إذا تساوت درجتان أو لم تكفِ المعلومات للترتيب، فاذكر ذلك وفسّر إجابتك.

- **أ** التأثير: كبير، الاحتمالية: عالية
- **ب** التأثير: صغير، الاحتمالية: عالية
- **ج** التأثير: كبير، الاحتمالية: منخفضة
- **د** التأثير: صغير، الاحتمالية: منخفضة

(2) من بين الخيارات التالية (أ - د)، اختر الوصف الأدق للتسلسل العام في نموذج الاستجابة للحوادث، مع مراعاة أن بعض الأنشطة قد تتداخل أو تتكرر.

- **أ** الاكتشاف ← الاستئصال ← الاحتواء ← الاستعادة
- **ب** التحضير ← الاكتشاف ← الاحتواء ← الاستئصال ← الاستعادة ← الدروس المستفادة والتحسين
- **ج** الاكتشاف ← الاستعادة ← الاحتواء ← الدروس المستفادة والتحسين
- **د** الاحتواء ← الاكتشاف ← الاستئصال ← التحضير

مصطلحات أساسية

الاحتواء – الحد من انتشار الضرر.

الاستئصال – إزالة السبب.

⭐ الخلاصة

تذكّر:
اتبع التسلسل العام للمراحل الست (تحضير ← اكتشاف ← احتواء ← استئصال ← استعادة ← الدروس المستفادة والتحسين) مع إمكانية التداخل أو العودة لمرحلة سابقة، وحدد أولويات المخاطر بناءً على التأثير× الاحتمالية.

⭐ فكّر وتحدَّ نفسك

تأمل: ما المرحلة من الاستجابة للحوادث التي تعتقد أنها الأصعب لتنفيذها بشكل جيد تحت الضغط، ولماذا؟

التحدي: اقترح شيئًا واحدًا يمكن لمؤسسة أن تُعده مسبقًا (المرحلة 1) من شأنه أن يجعل المراحل الأخرى أسرع.